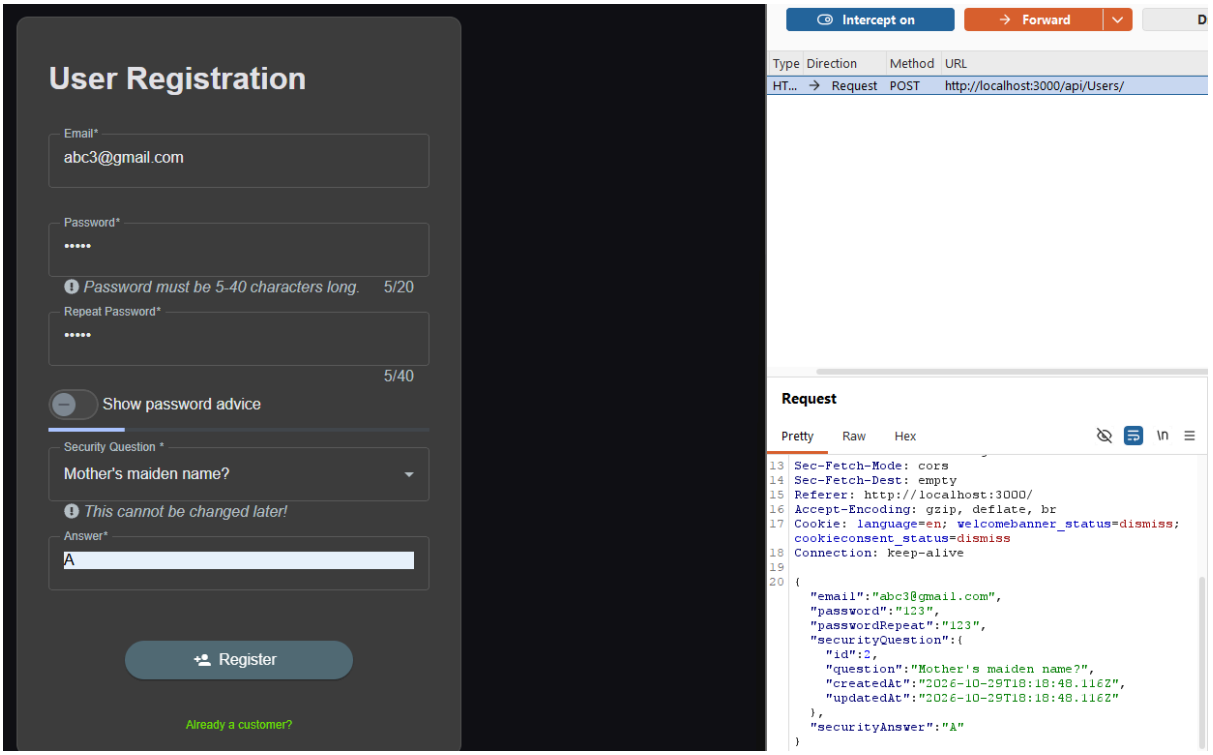
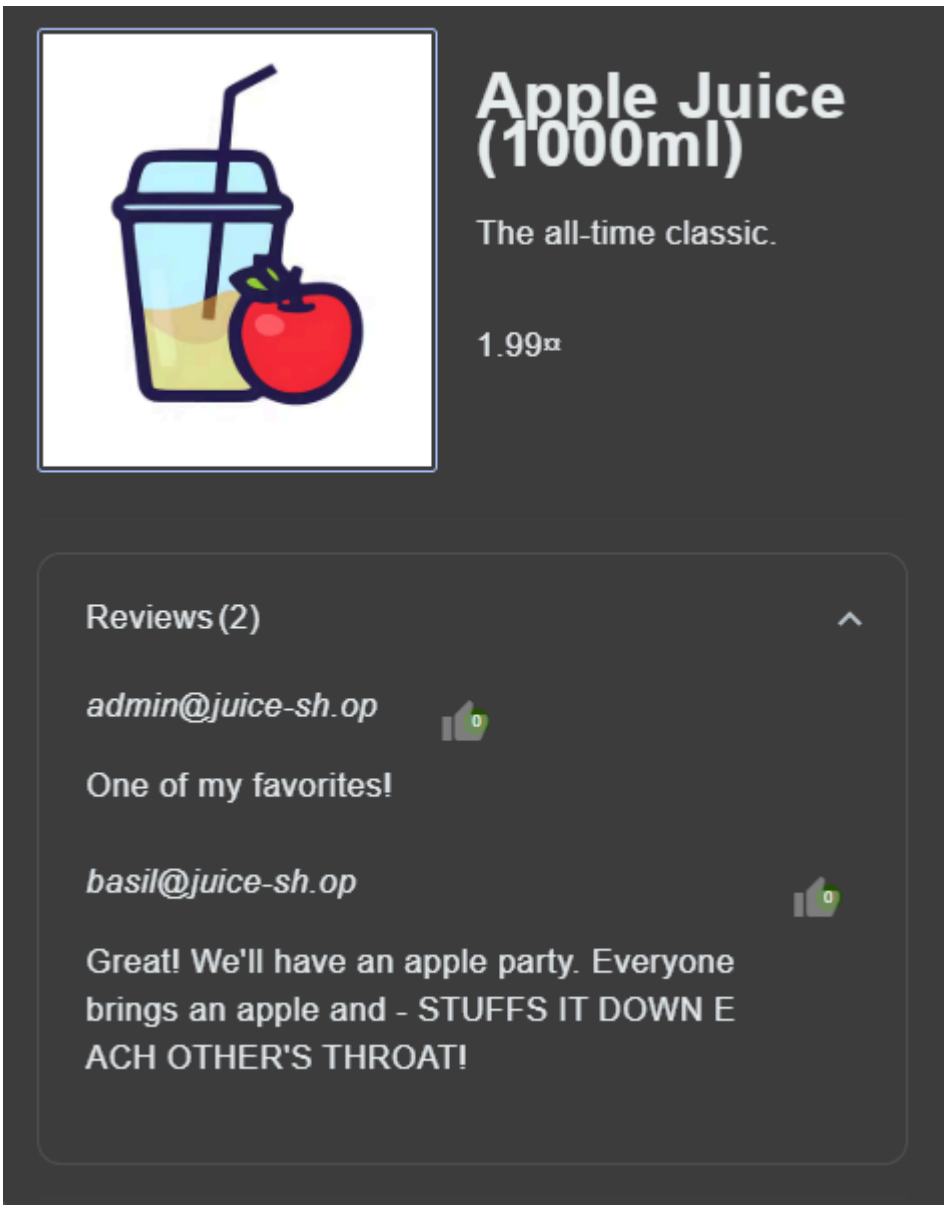
Bloco 2 trainee SACI

Nome: João Gabriel Tófoli Leite Cantarutti

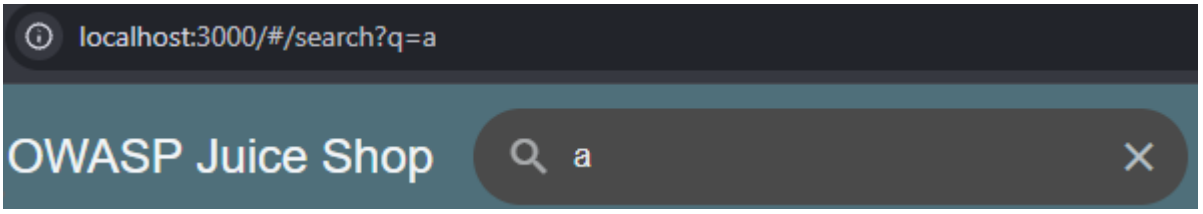
1. Alteração de requisição no cadastro: durante o processo de registro de usuário, a requisição HTTP foi interceptada utilizando o proxy e o valor referente à quantidade mínima de dígitos foi alterado manualmente. Embora a interface exigisse no mínimo 5 dígitos, foi possível enviar uma requisição contendo apenas 3 dígitos e o cadastro foi aceito pela aplicação.



2. Descoberta de informação privilegiada: durante a análise das avaliações dos produtos, foi identificado o endereço de e-mail associado ao usuário administrador (admin@juice-sh.op). A informação estava disponível diretamente na interface da aplicação, sem necessidade de autenticação privilegiada.

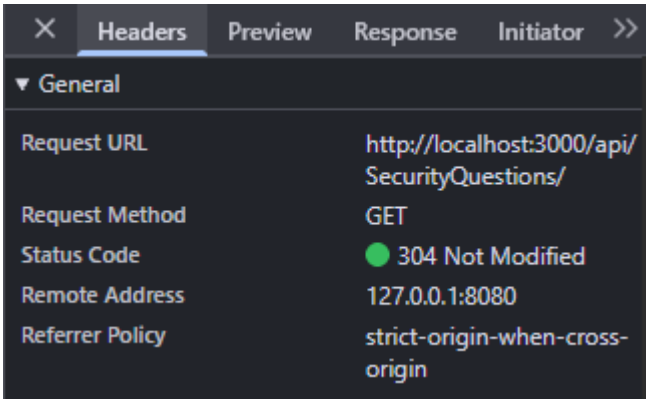


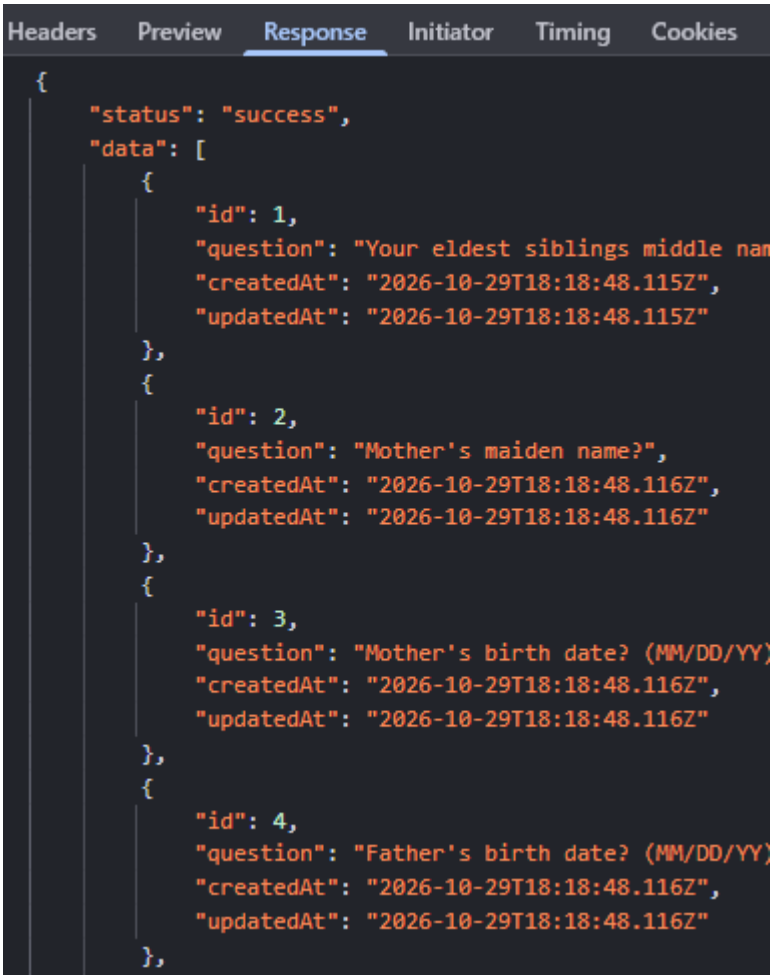
3. Parâmetro de busca identificado: ao utilizar a funcionalidade de pesquisa da aplicação, foi observado que o termo pesquisado é transportado na URL através do parâmetro q. A observação da URL permitiu identificar a estrutura “/search?q=apple”



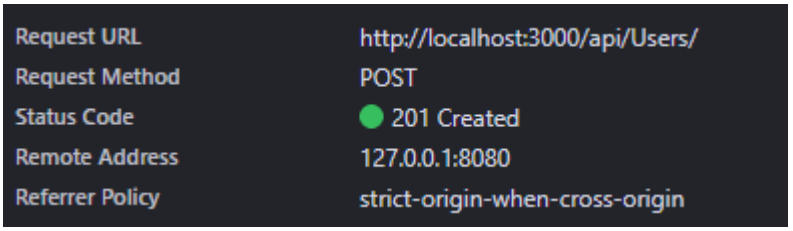
4. Mapeamento de endpoints: utilizando a ferramenta Network do navegador, foram monitoradas as requisições XHR/Fetch realizadas durante a utilização da aplicação. Foi possível identificar endpoints relacionados à autenticação, pesquisa e consulta de produtos. Essa técnica permitiu observar recursos utilizados pelo backend que não ficam necessariamente visíveis na interface gráfica. Exemplos:

Security Questions:



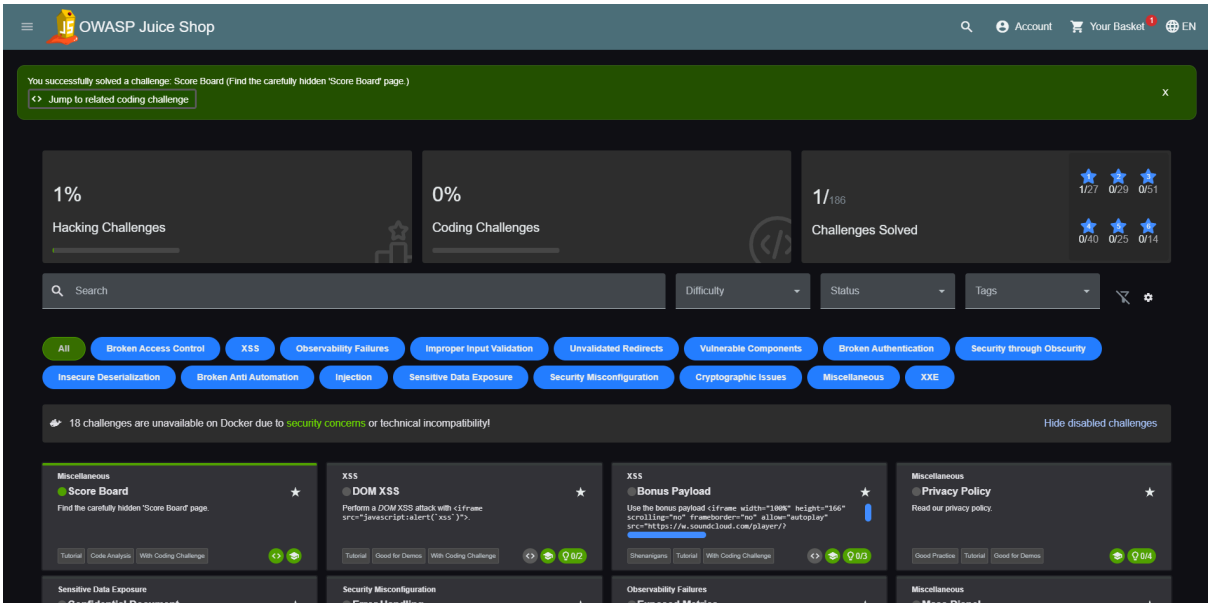


Register:



```
{
    "status": "success",
    "data": {
        "username": "",
        "role": "customer",
        "deluxeToken": "",
        "lastLoginIp": "0.0.0.0",
        "profileImage": "/assets/public/images/uploads/
        "isActive": true,
        "id": 28,
        "email": "asdad@asdf.com",
        "updatedAt": "2026-10-29T21:01:02.395Z",
        "createdAt": "2026-10-29T21:01:02.395Z",
        "deletedAt": null
    }
}
```


5. Funcionalidade não evidente na página inicial: durante o reconhecimento da aplicação foi localizado o Score Board, que apresenta os desafios de segurança existentes na aplicação. A existência dessa funcionalidade demonstra que a superfície funcional do sistema é maior do que aquela apresentada inicialmente ao usuário.



6. Diretório exposto: durante a enumeração de recursos foi testado o diretório /ftp. A aplicação disponibiliza recursos nesse caminho que não são apresentados diretamente através do menu principal. A descoberta demonstra a existência de uma superfície adicional acessível diretamente por URL.

